

Informe de Pentesting: Active Directory

Laboratorio: Attackitive Directory | Objetivo: DC-01

1. Resumen de la Fase: Explotación de Kerberos

Se ha identificado y explotado con éxito una vulnerabilidad de configuración en el servicio Kerberos conocida como **AS-REP Roasting**. Esta vulnerabilidad permite obtener hashes de contraseñas de usuarios que no requieren pre-autenticación.

2. Detalles del Objetivo

Dominio	attackitivedirectory.local
Dirección IP DC	10.0.2.10
Usuario Vulnerable	svcadmin (o svc-admin)

3. Metodología Paso a Paso

3.1. Identificación y Configuración (Windows Side)

Se confirmó que el usuario tiene habilitada la opción `Do not require Kerberos preauthentication (UF_DONT_REQUIRE_PREAUTH)`. Se verificó mediante PowerShell:

```
Get-ADUser -Identity "svcadmin" -Properties DoesNotRequirePreAuth | Select-Object Name, DoesNotRequirePreAuth  
# Resultado esperado: True
```

3.2. Extracción del Hash (Kali Side)

Utilizando la suite Impacket, se solicitó un ticket TGT para el usuario objetivo sin proporcionar contraseña:

```
impacket-GetNPUsers attackitivedirectory.local/svcadmin -no-pass -dc-ip 10.0.2.10
```

El sistema respondió con un hash Kerberos 5 AS-REP (tipo 23 - RC4-HMAC).

3.3. Ataque de Diccionario (Cracking)

Se utilizó **John the Ripper** para realizar un ataque offline contra el hash capturado.

```
john --format=krb5asrep --wordlist=dicc.txt hash_final.txt
```

4. Resultados Obtenidos

Credencial Comprometida:

Usuario: svcadmin

Contraseña: Laboratorio123

El crackeo fue instantáneo una vez configurado el formato correcto en John the Ripper.

5. Recomendaciones de Mitigación

- **Deshabilitar Pre-auth:** Asegurarse de que ninguna cuenta de usuario tenga marcada la casilla "No pedir la autenticación previa de Kerberos".
- **Políticas de Contraseñas:** Implementar contraseñas largas y complejas para mitigar ataques de diccionario offline.
- **Auditoría:** Monitorear eventos de solicitud de TGT sospechosos (ID de evento 4768).

